

NIST Special Publication 800-53 is an information security standard that provides a catalog of privacy and security controls for information systems. Originally intended for U.S. federal agencies except those related to national security, since the 5th revision it is a standard for general usage. It is published by the National Institute of Standards and Technology, which is a non-regulatory agency of the United States Department of Commerce. NIST develops and issues standards, guidelines, and other publications to assist federal agencies in implementing the Federal Information Security Modernization Act of 2014 (FISMA) and to help with managing cost effective programs to protect their information and information systems. Two related documents are 800-53A and 800-53B which provide guidance, and baselines based on 800-53.

Purpose

NIST Special Publication 800-53 is part of the Special Publication 800-series that reports on the Information Technology Laboratory's (ITL) research, guidelines, and outreach efforts in information system security, and on ITL's activity with industry, government, and academic organizations.

Specifically, NIST Special Publication 800-53 covers the steps in the Risk Management Framework that address security control selection for federal information systems in accordance with the security requirements in Federal Information Processing Standard (FIPS) 200. This includes selecting an initial set of baseline security controls based on a FIPS 199 worst-case impact analysis, tailoring the baseline security controls, and supplementing the security controls based on an organizational assessment of risk. The security rules cover 20 areas including access control, incident response, business continuity, and disaster recovery. A key part of the assessment and authorization (formerly certification and accreditation) process for federal information systems is selecting and implementing a subset of the controls (safeguards) from the Security Control Catalog (NIST 800-53, Appendix F). These controls are

the management, operational, and technical safeguards (or countermeasures) prescribed for an information system to protect the confidentiality, integrity, and availability of the system and its information. To implement the needed safeguards or controls, agencies must first determine the security category of their information systems in accordance with the provisions of FIPS 199, "Standards for Security Categorization of Federal Information and Information Systems." The security categorization of the information system (low, moderate or high) determines the baseline collection of controls that must be implemented and monitored. Agencies have the ability to adjust these controls and tailor them to fit more closely with their organizational goals or environments.

Originally intended for the U.S. government, NIST SP 800-53 expanded to a framework for security changes globally.

Compliance

Although any private organization can adopt the use of NIST 800-53 as a guiding framework for their security practice, all U.S. federal government agencies and contractors are required to comply with the framework in order to protect their critical data.

Agencies are expected to be compliant with NIST security standards and guidelines within one year of the publication date (February 2005) unless otherwise directed. Information systems that are under development are expected to be compliant upon deployment.

Collaboration with the Cybersecurity Framework

CSF (Cybersecurity Framework) and 800-53 covered each others weaknesses with CSF having more of a top-down decision-making process and NIST SP 800-53 having a bottom-up approach. The combination provided an easier approach for developers to create a new platform and software. Usage of Extensible Markup Language (XML) helped ease the

combination of CSF and 800-53 and eventually led to the creation of Baseline Tailor to help use the two security catalogs together.

The two relied on five primary functions:

ID - Identify

PR - Protect

DE - Detect

RS - Respond

RC - Recover

Control Baseline Levels

NIST 800-53 Low

In the event of a security breach that resulted in minor risk, the system deploys 149 different controls and enhancements that adds security ranging from Multi-factor authentication to basic security policies.

NIST 800-53 Moderate

In the event of a security breach that resulted in a moderate risk, the system deploys 138-287 different controls and enhancement to help combat against a more threatening attack through robust systems and advanced measures to hide important information.

NIST 800-53 High

In the event of a security breach that resulted and reached a severe risk, the system deploys 370 different controls and enhancements to defend against even the most volatile attacks. Results in the maximum security and best systems and measures to prevent further damage

to the system.

Revisions

Initial release

NIST Special Publication 800-53 was initially released in February 2005 as "Recommended Security Controls for Federal Information Systems."

First revision

NIST Special Publication 800-53 Revision 1 was initially released in December 2006 as "Recommended Security Controls for Federal Information Systems."

Second revision

NIST Special Publication 800-53 Revision 2 was initially released in December 2007 as "Recommended Security Controls for Federal Information Systems."

Third revision

The third version of NIST's Special Publication 800-53, "Recommended Security Controls for Federal Information Systems and Organizations," incorporates several recommendations from people who commented on previously published versions, who recommended a reduction in the number of security controls for low-impact systems, a new set of application-level controls and greater discretionary powers for organizations to downgrade controls. Also included in the final draft is language that allows federal agencies to keep their existing security measures if they can demonstrate that the level of security is equivalent to the standards being proposed by NIST. The third version also represents an effort to harmonize security requirements across government communities and between government and non-government systems. In the past, NIST guidance has not applied to government

information systems identified as national security systems. The management, operational, and technical controls in SP 800-53 Revision 3 provide a common information security language for all government information systems. The revised security control catalog also includes state-of-the-practice safeguards and countermeasures to address advanced cyber threats and exploits. Significant changes in this revision of the document include

A simplified, six-step risk management framework;

Additional security controls and enhancements for advanced cyber threats;

Recommendations for prioritizing security controls during implementation or deployment;

Revised security control structure with a new references section;

Elimination of security requirements from supplemental guidance sections;

Guidance on using the risk management framework for legacy information systems and for external information system services providers;

Updates to security control baselines based on current threat information and cyber attacks;

Organization-level security controls for managing information security programs;

Guidance on the management of common controls within organizations; and

Strategy for harmonizing FISMA security standards and guidelines with international security standard ISO/IEC 27001.

Fourth revision

As part of the ongoing cyber security partnership among the United States Department of Defense, the intelligence community, and the federal civil agencies, NIST has launched its biennial update to Special Publication 800-53, "Security and Privacy Controls for Federal Information Systems and Organizations," with an initial public draft released on February 28, 2012. The 2011-12 initiative will include an update of current security controls, control enhancements, supplemental guidance and an update on tailoring and supplementation

guidance that form key elements of the control selection process. Key focus areas include, but are not limited to:

Insider threats;

Software application security (including web applications);

Social networking, mobiles devices, and cloud computing;

Cross domain solutions;

Advanced persistent threats;

Supply chain security;

Privacy.

Revision 4 is broken up into 18 control families, including:

AC - Access Control

AU - Audit and Accountability

AT - Awareness and Training

CM - Configuration Management

CP - Contingency Planning

IA - Identification and Authentication

IR - Incident Response

MA - Maintenance

MP - Media Protection

PS - Personnel Security

PE - Physical and Environmental Protection

PL - Planning

PM - Program Management

RA - Risk Assessment

CA - Security Assessment and Authorization

SC - System and Communications Protection

SI - System and Information Integrity

SA - System and Services Acquisition

Information on these control families and the controls contained within can be found on the NIST website at the following link: <https://nvd.nist.gov/800-53/Rev4>

Network Access Control (NAC) is a tool that was utilized to help reach NIST 800-53 standards, and used the Access Control resources to help authorize devices that wished to access the network. NAC also provided an easy and adaptable control to meet any organization security needs.

Fifth revision

NIST SP 800-53 Revision 5 removes the word "federal" to indicate that these regulations may be applied to all organizations, not just federal organizations. The first public draft was published on August 15, 2017. A final draft release was set for publication in December 2018, with the final publication date set for March 2019." Per the NIST Computer Security Resource Center (CSRC), major changes to the publication include:

Making the security and privacy controls more outcome-based by changing the structure of the controls;

Fully integrating the privacy controls into the security control catalog creating a consolidated and unified set of controls for systems and organizations;

Separating the control selection process from the actual controls, thus allowing the controls to be used by different communities of interest including systems engineers, software developers, enterprise architects; and mission/business owners;

Eliminating the term "information system" and replacing it with the term "system" so the

controls can be applied to any type of system including, for example, general-purpose systems, cyber-physical systems, industrial/process control systems, and IoT devices;

De-emphasizing the federal focus of the publication to encourage greater use by nonfederal organizations;

Promoting integration with different risk management and cyber security approaches and lexicons, including the Cybersecurity Framework;

Clarifying the relationship between security and privacy to improve the selection of controls necessary to address the full scope of security and privacy risks; and

Incorporating new, state of the practice controls based on threat intelligence and empirical attack data, including controls to strengthen cybersecurity and privacy governance and accountability.

As of September 2019, Revision 5 was delayed due to a potential disagreement among the Office of Information and Regulatory Affairs (OIRA) and other U.S. agencies.

The final version of Revision 5 was released on September 23, 2020 and is available on the NIST website at the following link:
<https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

Revision 5 Control Families

The control families became a larger factor after Revision 5 and have the purpose of providing safeguards and protection for accomplishing security objectives. Every control is involved in a different policy and processes used by the systems security measures. After the upgrade to Revision 5 from Revision 4, the number of control families increased from 18 to 20 with the inclusion of Personally Identifiable Information Processing and Transparency (PT) and Supply Chain Risk Management (SR).

NIST offers the power of controls to the government, but the ability to operate an ATO is required first. The usage of an ATO determines which controls are activated and utilized for

the system automatically. Systems that involve greater risks to the framework, will be issued an increased number of controls to defend against outside threats. One term that is used for the controls is labeled as topics, or in other cases, Control Families.

The development of Revision 5 allows the public and private sectors to use NIST in order to control major growing threats of hostile attacks and natural disasters, reducing as much damage from attacks the moment they occur.

Controls

A main overview of the controls were to provide protective measures for the system and regulate risks that are taken and the solutions in order to comply with different standards. The main goal of the system is to protect the information of different users and encourages companies to take different measures in improving the security and protection of the frameworks within the supervision of Revision 5. Controls are not expected to be sustained over time, but the process of withdrawing controls from different revisions will be utilized and replaced with existing or new controls in order to replicate its place in the system. Controls are expected to take its place until they are pronounced as not necessary, or ineffective to the current state.

Revision 5 built SP 800-53 to a new height after the past seven years since the last major update to NIST's security guidelines. Further enhanced to comply with the security interests of the United States and the millions of downloads it has procured since 2013.

Revision 5 was tested in a scenario that involved 42 different risks in order to test the reliability of the frame work and success of the new revision. Out of the 42 different scenarios, 12 were accepted and 30 different scenarios were mitigated by the system.

800-53A

NIST Special Publication 800-53A provides a set of procedures for conducting assessments of

security controls and privacy controls employed within federal information systems and organizations. The procedures are customizable and can be easily tailored to provide organizations with the needed flexibility to conduct security control assessments and privacy control assessments that support organizational risk management processes and that are aligned with the stated risk tolerance of the organization. Information on building effective security assessment plans and privacy assessment plans is also provided along with guidance on analyzing assessment results.

Revision 1

NIST Special Publication 800-53A is titled "Guide for Assessing Security Controls in Federal Information Systems and Organizations." This version will describe testing and evaluation procedures for the 17 required control families. These assessment guidelines are designed to enable periodic testing and are used by federal agencies to determine what security controls are necessary to protect organizational operations and assets, individuals, other organizations, and the nation.

According to Ron Ross, senior computer scientist and information security researcher at NIST, these guidelines will also allow federal agencies to assess "if mandated controls have been implemented correctly, are operating as intended, and are... meeting the organization's security requirements."

To do this, version A describes assessment methods and procedures for each of the security controls mandated in Special Publication 800-53. These methods and procedures are to be used as guidelines for federal agencies. These guidelines are meant to limit confusion and ensure that agencies interpret and implement the security controls in the same way.

Revision 4

NIST SP 800-53A Revision 4 is Assessing Security and Privacy Controls in Federal Information

Systems and Organizations. The Revision number went from Revision 1 to Revision 4 in order to better reflect the NIST Special Publication 8002005-53 it is meant to be used with.

800-53B

NIST Special Publication 800-53B provides a set of baseline security controls and privacy controls for information systems and organizations. The baselines establish default controls based on FISMA rates (Privacy, Low, Moderate, and High) and can be easily tailored to organizational risk management processes.

Information on building effective security assessment plans and privacy assessment plans is also provided along with guidance on analyzing assessment results.

Initial release

NIST Special Publication 800-53B was initially released in September 2020 as "Control Baselines for Information Systems and Organizations."

Latest Release

NIST released SP 800-53 version 5.2.0 on August 27, 2025, to improve security and reliability of existing software to align with Executive Order 14306. Release 5.2.0 improves system and software resilience and assists in security measures. Releases 5.2.0 provides updates to SP 800-53A but no additional updates to SP 800-53B. Release 5.2.0 brought new Control Enhancements and Revisions to existing controls such as (SA-15(13), SA-24, SI-02(07) and SI-07(12)).

Expansion into Companies

Amazon Web Services

NIST SP 800-53 Revision 5 is one of the main frameworks provided towards AWS's systems.

Provides a vast list of security measures and privacy requirements that every company must comply with. Revision 5 is automated within the systems to provide guidelines and system checks.

Within AWS's system, the service also provides the details behind Revision 5 and its framework. Uses prebuilt features and controls that comply with NIST standards and further grouped into control sets in order to sort out different audits within the system. The service utilizes a total of 132 automated control , 875 Manual control, and 20 control sets.

Google Cloud Services

NIST provides its services of Revision 5 to GCS and outlines its guidelines for security. SP 800-53 is built to lay out responsibilities in the Federal Information Security Management Act (FISMA). Further controls were accessed and utilized in the Google Workspace services alongside the Google Cloud Services.

Microsoft Azure

NIST provides its services in compliance with Microsoft Azure and regulates the framework to a standard. Azure utilizes the Revision 5 domains and controls within the Azure policies and security.

TCCE

The Technical Control Compliance Evaluation checklist was created to check the reliability and validity of a framework which included NIST 800-53's framework. Utilized a combination of 55 steps and 66 shell commands to test NIST 800-53's 48 different controls. Ended up failing 17 controls that did not reach the standard requirement of TCCE and was left off for major improvements. NIST 800-53 was eventually used to create future security basics and different frameworks that utilized 800-53's reliability.

See also

NIST SP 800-37

NIST SP 800-90A

NIST SP 800-90B

NIST SP 800-92

NIST RMF

ISO/IEC 27001

References

Further reading

Ross, Ron; Jahnson, Arnold; Katzke, Stu; Toth, Patricia; Stoneburner, Gary; Rogers, George (2008), Guide for Assessing the Security Controls in Federal Information Systems, Building Effective Security Assessment Plans (PDF), retrieved February 14, 2011

Schou, Corey (2006). Information Assurance for the Enterprise. Boston: McGraw Hill Irwin. ISBN 978-0-07-225524-9.

External links

Official website